

Bài 15: Hướng dẫn phân quyền admin

Nội dung

Bổ sung cột role vào bảng users với role (user, admin) để phân biệt người dùng thường và admin.

Tạo middleware AdminMiddleware để chỉ admin được phép truy cập các chức năng quản trị tin tức (sửa/xoá).

Áp dụng middleware trong NewsController và ẩn các nút CRUD với người không phải admin.

Tạo seeder tài khoản admin mẫu để kiểm thử.

Bước 1: Thêm cột role vào bảng users

Tạo file migration chỉnh sửa bảng users:

php artisan make:migration add_role_to_users_table --table=users

Trong file migration vừa tạo (trong database/migrations/), chỉnh sửa nội dung như sau:

```
public function up(): void
{
    Schema::table('users', function (Blueprint $table) {
        $table->string('role')->default('user')->after('email');
    });
}

public function down(): void
{
    Schema::table('users', function (Blueprint $table) {
        $table->dropColumn('role');
    });
}
```

Chạy migration:

php artisan migrate

[Chụp ảnh giao diện kết quả vào đây]

Bước 2. Tạo Middleware AdminMiddleware

Tạo middleware mới:

php artisan make:middleware AdminMiddleware

Trong file **app/Http/Middleware/AdminMiddleware.php**, sửa nội dung như sau:

```
<?php

namespace App\Http\Middleware;

use Closure;
use Illuminate\Http\Request;
use Symfony\Component\HttpFoundation\Response;

class AdminMiddleware
{
    public function handle(Request $request, Closure $next): Response
    {
        // Kiểm tra nếu người dùng chưa đăng nhập hoặc không phải admin
        if (!auth()->check() || auth()->user()->role !== 'admin') {
            abort(403, 'Bạn không có quyền truy cập chức năng này.');
        }

        return $next($request);
    }
}
```

Bước 3. Đăng ký Middleware

Từ Laravel 11 trở đi **không còn app/Http/Kernel.php nữa**; middleware (trước đây làm trong App\Http\Kernel) được chuyển vào **bootstrap/app.php** thông qua `withMiddleware()` (đây là hành vi mặc định trên ứng dụng mới) do vậy middleware giờ được cấu hình trong **bootstrap/app.php**.

Do vậy, để đăng ký Middleware với các bản thấp hơn 11:

Mở file **app/Http/Kernel.php** và thêm middleware vừa tạo vào thuộc tính **\$routeMiddleware**:

```
protected $routeMiddleware = [
    'auth' => \App\Http\Middleware\Authenticate::class,
```

```
'check.admin' =>
\App\Http\Middleware\AdminMiddleware::class,
];
```

Đăng ký Middleware với các bản từ 11 trở lên:

Cần đăng ký alias / thêm vào middleware group / thêm global trong **bootstrap/app.php** bằng **->withMiddleware(...)**

Mở **bootstrap/app.php** và thêm vào khối **withMiddleware()** (nằm trong return Application::configure(...)):

```
<?php
```

```
use Illuminate\Foundation\Application;
use Illuminate\Foundation\Configuration\Exceptions;
use Illuminate\Foundation\Configuration\Middleware;
use App\Http\Middleware\AdminMiddleware;
```

```
return Application::configure(basePath: dirname(__DIR__))
    ->withRouting(
        web: __DIR__.'/../routes/web.php',
        commands: __DIR__.'/../routes/console.php',
        health: '/up',
    )
    ->withMiddleware(function (Middleware $middleware): void {
        // Đăng ký alias (route middleware alias)
        $middleware->alias([
            'check.admin' => AdminMiddleware::class,
        ]);
    })
    ->withExceptions(function (Exceptions $exceptions): void {
        //
    })->create();
```

Bước 4. Áp dụng Middleware cho các route của Admin

Mở file **routes/web.php** (hoặc file riêng bạn đã tách, ví dụ **routes/news.php**), chỉnh sửa nhóm route của admin:

```
use App\Http\Controllers\Admin\NewsController;
```

```
Route::middleware(['auth', 'check.admin'])->group(function () {
```

```
    Route::get('/news/{id}/edit', [NewsController::class, 'edit'])->name('news.edit');
```

```

Route::put('/news/{id}', [NewsController::class, 'update'])->name('news.update');

Route::delete('/news/{id}', [NewsController::class, 'destroy'])->name('news.destroy');

});

Route::middleware(['auth'])->group(function () {

    Route::get('/news/create', [NewsController::class, 'create'])->name('news.create');

    Route::post('/news', [NewsController::class, 'store'])->name('news.store');

});

```

Ở đây, middleware **auth** đảm bảo người dùng đã đăng nhập, còn **check.admin** đảm bảo người đó có vai trò quản trị.

Bước 5. Chỉnh sửa Controller để xử lý lỗi quyền hạn

Trong **app/Http/Controllers/Admin/NewsController.php**, bạn có thể bổ sung kiểm tra trong các phương thức nếu muốn chi tiết hơn, ví dụ:

```

public function destroy($id)
{
    if (auth()->user()->role !== 'admin') {
        abort(403, 'Bạn không có quyền xóa tin tức.');
```

```

    }
    News::findOrFail($id)->delete();
    return redirect()->route('admin.news.index')->with('success', 'Đã xóa tin tức thành công');
}

```

Bước 6. Ẩn các nút thao tác khi không phải admin

Trong view hiển thị danh sách tin tức (**resources/views/admin/news/index.blade.php**), sửa lại như sau:

```

@extends('layouts.myapp')
@section('title', 'Danh sách tin tức')
@section('content')
    <h1>Danh sách tin tức</h1>
    @auth
    <a href="{{ route('news.create') }}">Thêm tin tức mới</a>
    @endauth
    <ul>
        @foreach($news as $item)
            <li>

```

```

<a href="{{ route('news.show', $item->id) }}">{{ $item->title }}</a>
@if(auth()->check() && auth()->user()->role === 'admin')
<a href="{{ route('news.edit', $item->id) }}">Sửa</a>
<form action="{{ route('news.destroy', $item->id) }}" method="POST"
style="display:inline">
    @csrf
    @method('DELETE')
    <button type="submit">Xóa</button>
</form>
@endif
</li>
@endforeach
</ul>
<div >
    {{ $news->links() }}
</div>

```

@endsection

Bước 7. Seeding tài khoản admin và user để test

Tạo seeder cho User

php artisan make:seeder UserSeeder

Mở file database/seeder/UserSeeder.php chỉnh sửa phần run():

```

namespace Database\Seeders;

use Illuminate\Database\Seeder;
use Illuminate\Support\Facades\Hash;
use App\Models\User;

class UserSeeder extends Seeder
{
    public function run(): void
    {
        // Tạo tài khoản admin
        User::create([
            'name' => 'Admin User',
            'email' => 'admin@example.com',
            'password' => Hash::make('12345678'),
            'role' => 'admin',
        ]);
    }
}

```

```
// Tạo tài khoản user bình thường
User::create([
    'name' => 'Normal User',
    'email' => 'user@example.com',
    'password' => Hash::make('12345678'),
    'role' => 'user',
]);
}
```

Chạy lệnh seeding dữ liệu:

```
php artisan db:seed --class=UserSeeder
```

[Đăng nhập lần lượt 2 tài khoản và chụp ảnh kết quả vào đây]